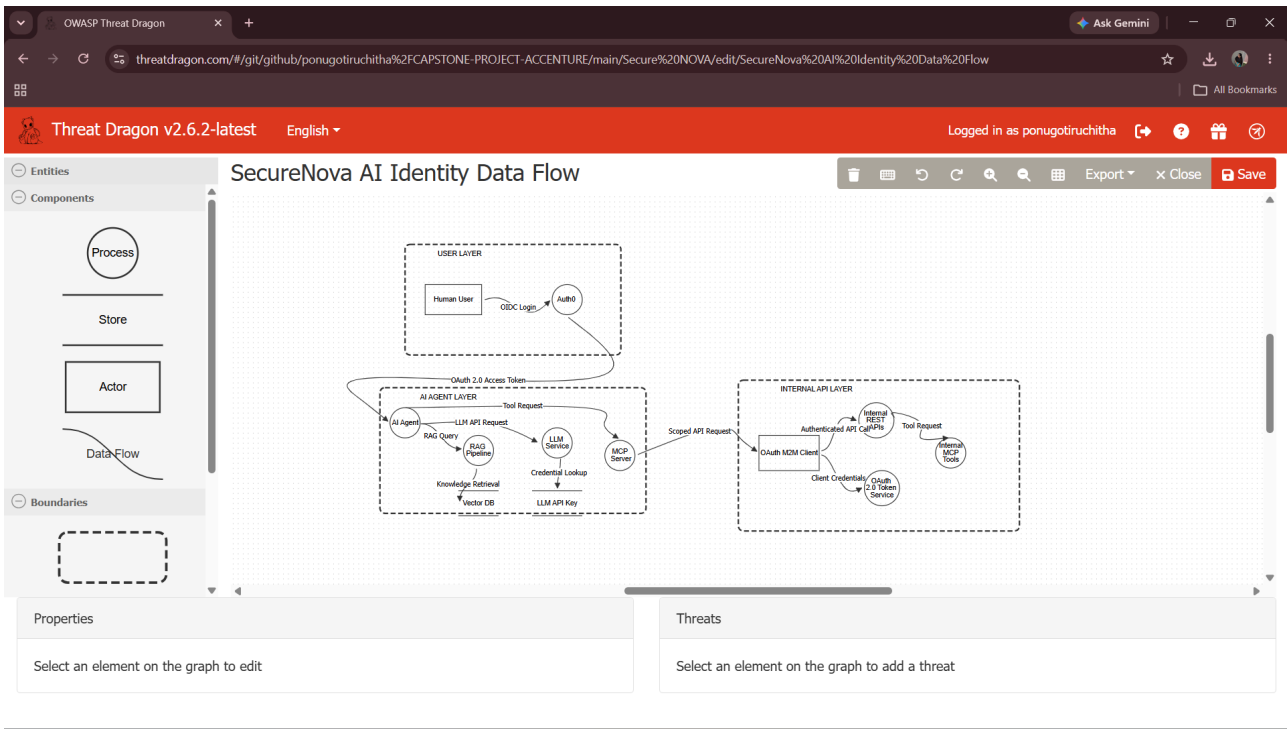


CAPSTONE PROJECT DOCUMENTATION

PROJECT 1 : Threat Model the AI Identity System

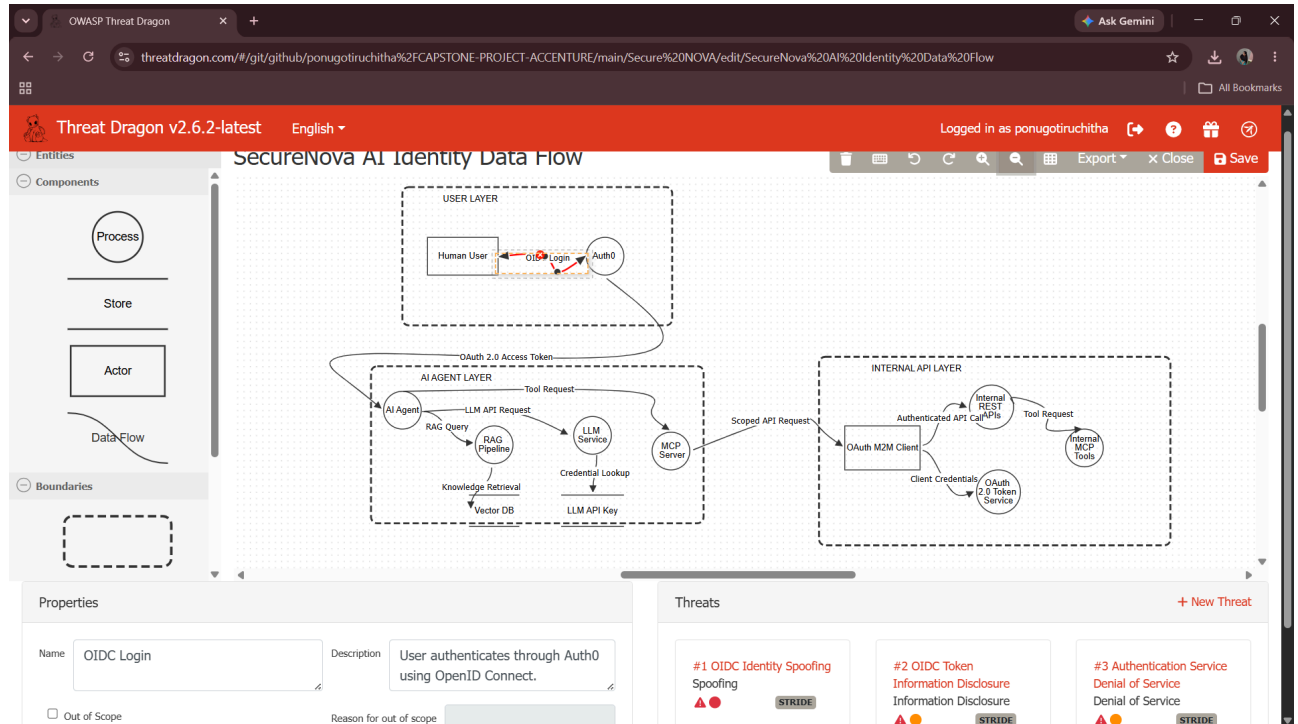
Screenshot 1:SecureNova AI Identity Data Flow

This screenshot presents the completed SecureNova AI Identity Data Flow in OWASP Threat Dragon. It shows the main trust boundaries and interactions across the User Layer, AI Agent Layer, and Internal API Layer, including Human User → Auth0 OIDC Login, OAuth 2.0 access-token flow, RAG/Vector DB retrieval, LLM service access, MCP tool requests, and OAuth M2M authentication.



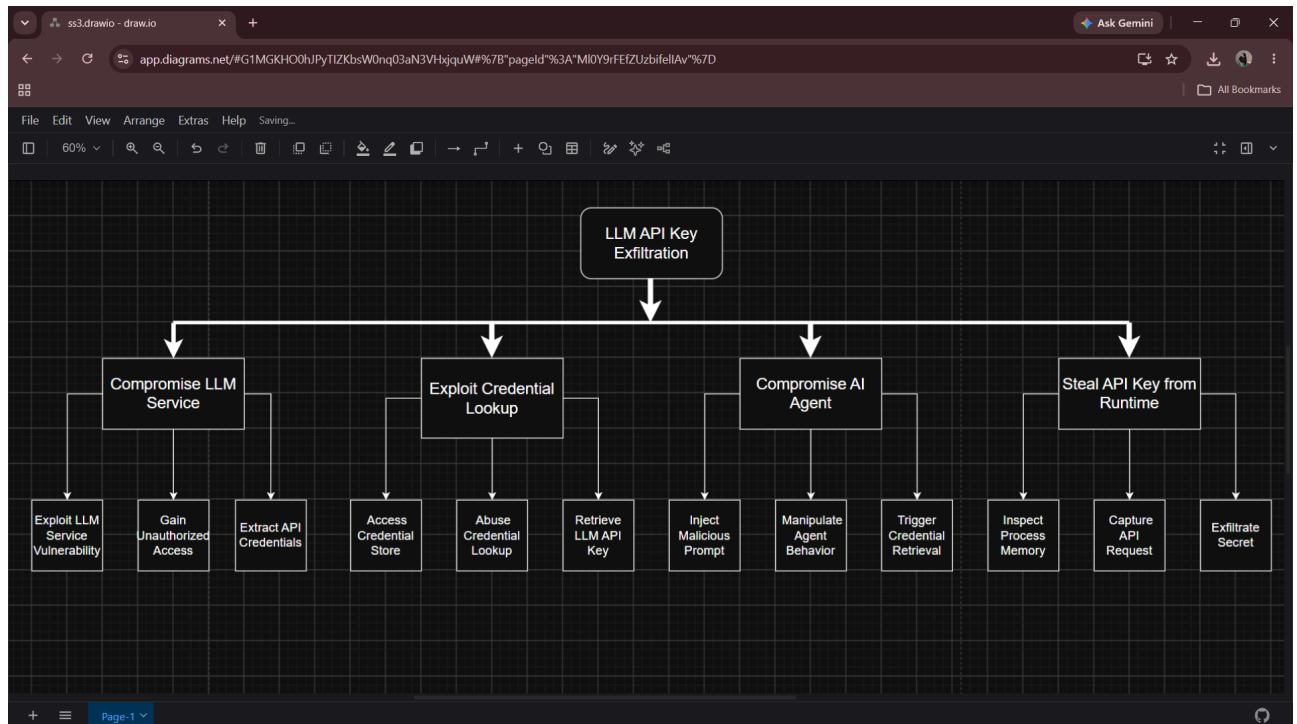
Screenshot 2 : Threats Identified in Threat Dragon

This screenshot shows the threat analysis applied to the data-flow model. The selected OIDC Login flow is associated with STRIDE-based threats including OIDC Token Tampering, OIDC Token Information Disclosure, and Authentication Service Denial of Service, demonstrating how threats were attached to the modeled authentication flow.



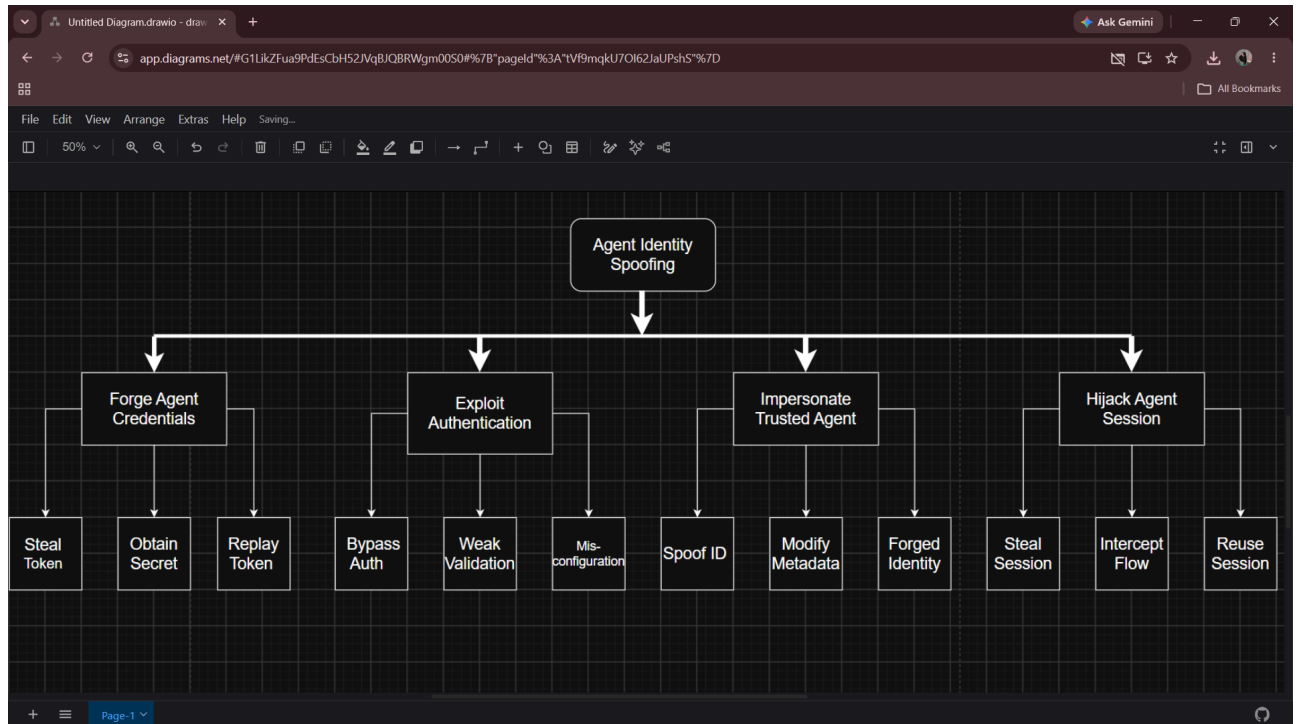
Screenshot 3 : Attack Tree- LLM API Key Exfiltration

This attack tree models LLM API Key Exfiltration as the root threat. It breaks the threat into paths such as compromising the LLM service, exploiting credential lookup, compromising the AI agent, and stealing an API key from runtime, with lower-level attack actions shown beneath each branch.



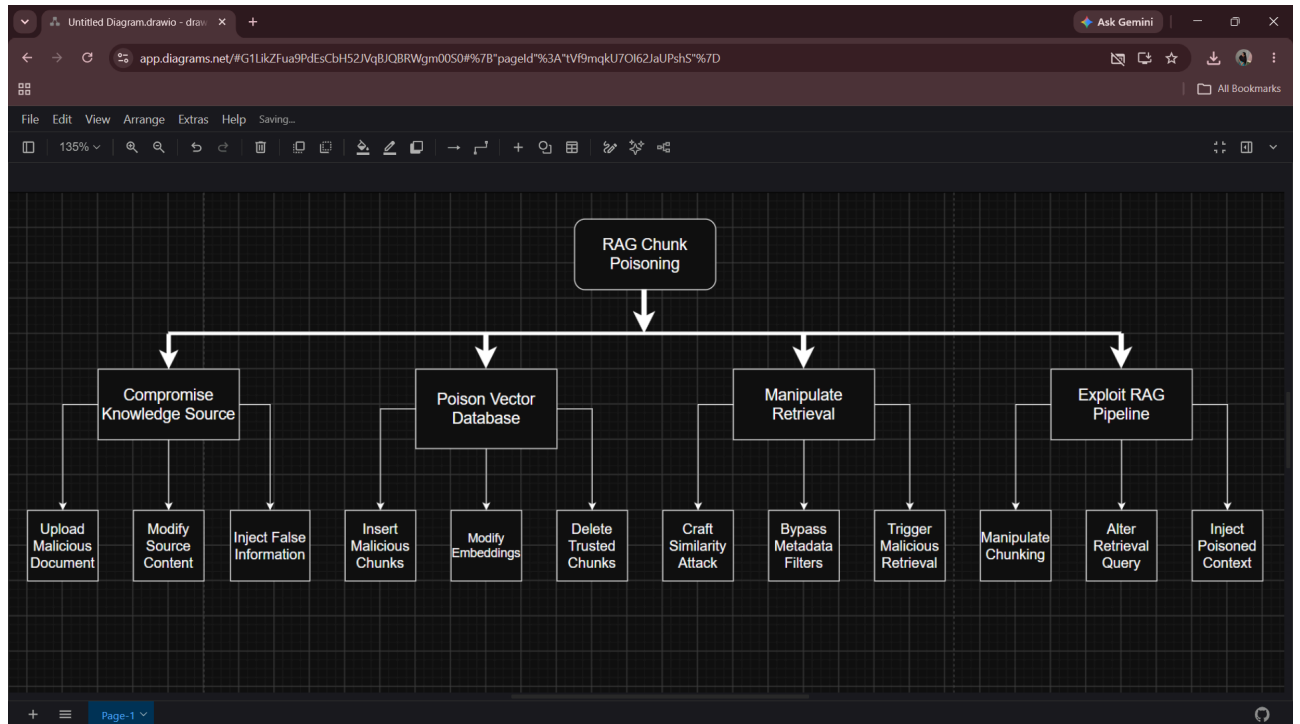
Screenshot 4 : Attack Tree-Agent Identity Spoofing

This attack tree models Agent Identity Spoofing. The branches cover forging agent credentials, exploiting authentication, impersonating a trusted agent, and hijacking an agent session, with example actions such as stealing or replaying tokens, bypassing authentication, spoofing identity, and reusing a session.



Screenshot 5 :Attack Tree- RAG Chunk Poisoning

This attack tree models RAG Chunk Poisoning. It identifies attack paths involving compromise of a knowledge source, poisoning the vector database, manipulating retrieval, and exploiting the RAG pipeline, including malicious documents, altered embeddings, manipulated chunking, and poisoned retrieval context.



Screenshot 6 : STRIDE Threat Matrix

This screenshot shows the SecureNova STRIDE Threat Matrix. It maps each identity or data flow to Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege scenarios, providing a systematic threat-coverage view across the architecture.

SecureNova STRIDE Threat Matrix

A	B	C	D	E	F	G	H	I
ID	Identity Flow	Spoofing	Tampering	Repudiation	Information Disclosure	Denial of Service	Elevation of Privilege	
Human User → AuthN (OIDC Login)	User impersonation	Modify authentication request	Deny authentication activity	Expose identity/token data	Flood login endpoint	Bypass authentication		
Human User → AI Agent	Spoof user identity	Modify user request	Deny submitted request	Expose user information	Flood agent requests	Gain unauthorized agent privileges		
Auth0 → AI Agent (OAuth 2.0 Access Token)	Forge/steal token	Modify token claims	Deny token usage	Token disclosure	Flood token requests	Abuse token scope		
AI Agent → RAG Pipeline (RAG Query)	Spoof agent request	Modify RAG query	Deny retrieval request	Expose retrieved information	Flood RAG pipeline	Retrieve unauthorized knowledge		
RAG Pipeline → Vector DB (Knowledge Retrieval)	Spoof RAG service	Poison/modify RAG chunks	Deny database activity	Expose indexed data	Exhaust Vector DB	Access restricted chunks		
AI Agent → LLM Service (LLM API Request)	Spoof agent	Modify LLM request	Deny LLM request	Expose prompts/context	Flood LLM service	Obtain unauthorized model capability		
LLM Service → LLM API Key (Credential Lookup)	Spoof credential requester	Modify credential request	Deny credential access	Expose API key	Flood credential service	Retrieve privileged credential		
AI Agent → MCP Server (Tool Request)	Spoof agent identity	Modify tool request	Deny tool invocation	Expose tool data	Flood MCP server	Invoke unauthorized tool		
OAuth M2M Client → OAuth 2.0 Token Service (Client Credentials)	Spoof M2M client	Modify client credentials	Deny token request	Expose client secret/token	Flood token endpoint	Obtain excessive scope		
OAuth M2M Client → Internal REST APIs (Authenticated API Call)	Spoof M2M client	Modify API request	Deny API action	Expose API data	Flood API	Access unauthorized API functions		
MCP Server → OAuth M2M Client (Scoped API Request)	Spoof MCP identity	Modify scoped request	Deny API request	Expose authorization data	Flood API requests	Abuse API scope		
Internal REST APIs → Internal MCP Tools (Tool Request)	Spoof API caller	Modify tool request	Deny tool execution	Expose tool output	Exhaust tool service	Execute unauthorized tools		

Screenshot 7 :Risk Register and Risk Scoring

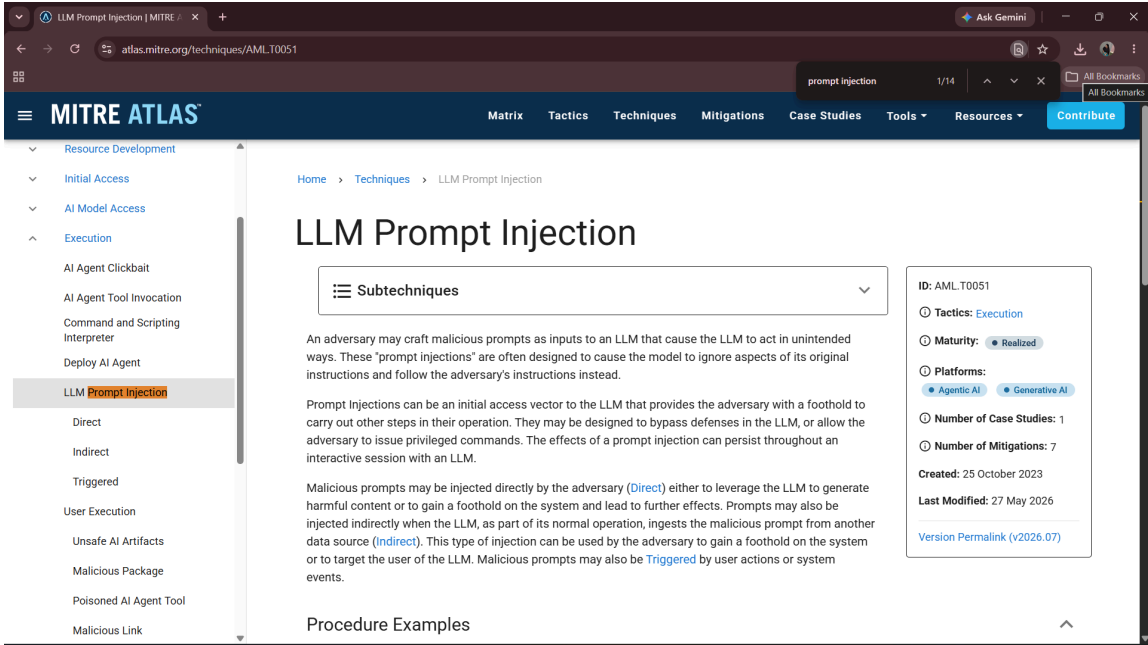
This screenshot presents the risk register with Risk ID, Threat, Identity, Likelihood, Impact, Risk Score, Risk Level, Owner, and Mitigation. The highest-scored risks include LLM API Key Exfiltration, Agent Identity Spoofing, RAG Chunk Poisoning, and Unauthorized API Scope Elevation, with critical and high risk levels and corresponding mitigations.

[illegible]

Screenshot 8 :MITRE ATLAS Mapping Evidence

Screenshot 8.1:

This screenshot provides the supporting MITRE ATLAS technique evidence for AML.T0051, LLM Prompt Injection. The page identifies the technique under the Execution tactic and describes how malicious prompts can cause an LLM to ignore intended instructions and follow adversarial instructions, supporting the mapping used for the LLM API Key Exfiltration attack tree.



Screenshot 8.2:

This screenshot records the MITRE ATLAS evidence for the three attack trees. Tree 1 maps LLM API Key Exfiltration to AML.T0051 (LLM Prompt Injection), Tree 2 records the identity/authentication-related ATLAS mapping requirement, and Tree 3 maps RAG Chunk Poisoning to AML.T0070 (RAG Poisoning).

